

MSARAT BROWSER CDP REMOTE DEBUGGING

A process-telemetry candidate for browser-mediated command and control through headless Chrome or Edge.

PRODUCTION CANDIDATE

CONFIDENCE: MEDIUM



REPORT DATE

24 July 2026

VERSION

v1.0

PRIMARY TELEMETRY

Microsoft Defender XDR ·
DeviceProcessEvents

ATT&CK TACTICS

Command and Control ·
Execution

Operational research dossier. All implementations are untested sketches and require target-environment validation.

INDEPENDENT THREAT RESEARCH · DETECTION ENGINEERING DOSSIER

RESEARCH NOTE · 001



EXECUTIVE ASSESSMENT

Decision-grade summary for SOC and detection engineering.

ASSESSMENT LAYER

EXECUTIVE SUMMARY

msaRAT Browser CDP Remote Debugging

Cisco Talos directly analyzed msaRAT and observed it launching Chrome or Edge in headless mode with Chrome DevTools Protocol remote debugging enabled. The browser, rather than the RAT process, performs the Cloudflare Workers signaling and WebRTC/TURN communication.

WHY IT MATTERS

Operational value 9.2 / 10

The conjunction of a mainstream browser, headless mode and an exposed remote-debugging port is directly visible in process creation telemetry and is substantially more specific than generic browser execution.

Medium01

CONFIDENCE

9.202

OPERATIONAL VALUE

Production Candidate03

READINESS

SOURCE-CONFIRMED FACTS

- msaRAT locates Chrome or Edge and launches it through CreateProcessW.
- The launch applies headless and CDP remote-debugging flags.
- The RAT controls C2 through the browser and does not make the C2 connection itself.

ANALYTICAL ASSESSMENT

- The process launch is the most durable endpoint observable in the published chain.
- A match indicates a browser automation or debugging session; it does not prove msaRAT.
- Parent process, browser profile path and subsequent network activity should drive triage.

ASSUMPTIONS

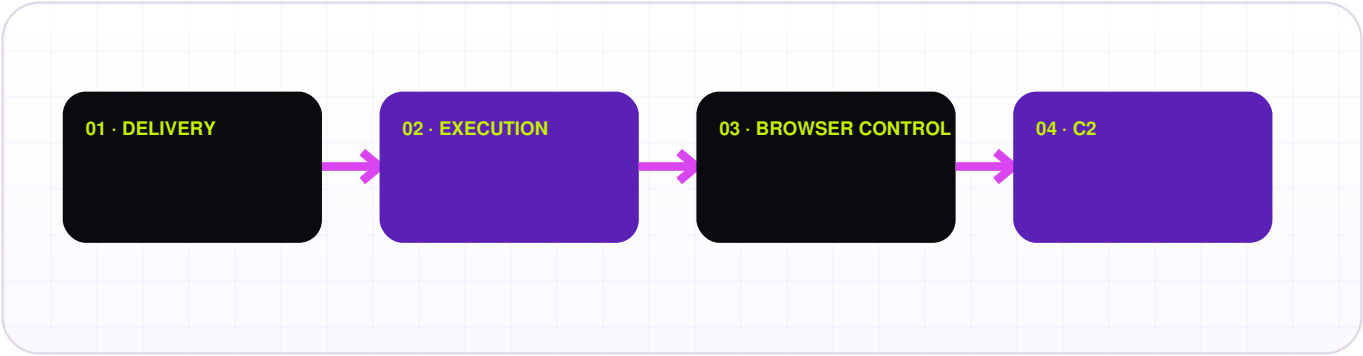
- Full command lines are populated in DeviceProcessEvents.
- The deployed sensor records browser processes launched by MSI custom actions.
- Authorized automation can be baselined by device role, parent and command line.

02

THREAT MECHANICS

Source-observed chain and detection value.

EVIDENCE FLOW



THREAT MECHANICS AND VISIBILITY

STAGE	BEHAVIOR	OBSERVABLE EVIDENCE	VALUE
Delivery	curl downloads update_ms.msi to ProgramData	Process command line and file creation	High
Execution	MSI custom action loads lib.dll in memory	Installer execution; DLL memory load may be incomplete	Medium
Browser control	Chrome or Edge starts headless with CDP remote debugging	Browser process command line	High
C2	Browser creates WebRTC DataChannel through TURN	Browser-attributed network telemetry	Medium

Evidence boundary

The report does not infer unseen payload content or compromise outcome. Every query targets the directly observable behavior identified above.



TELEMETRY AND EVIDENCE MODEL

Required data, fields and visibility constraints.

TELEMETRY

PRIMARY DATA SOURCE

Microsoft Defender XDR - DeviceProcessEvents

The selected platform provides the most direct observable for the behavior. Optional enrichment must not be treated as guaranteed.

REQUIRED QUALITY

Complete raw values and stable entity context

Retention, truncation, parsing and sensor coverage must be confirmed before operational deployment.

REQUIRED FIELDS

FIELD	RELIABILITY	PURPOSE
Timestamp	Documented	Process creation time
DeviceId / DeviceName	Documented	Stable device context
FileName	Documented	chrome.exe or msedge.exe
ProcessCommandLine	Documented	Headless and remote-debugging flags
InitiatingProcessFileName	Documented	Parent-process triage
SHA1 / ReportId	Documented	Investigation and event uniqueness

Required

The primary event, host identity and directly filtered values.

Optional enrichment

Signer, prevalence, parent lineage, network activity or ownership context when available.



DETECTION LOGIC

Primary-platform implementation and condition rationale.

UNTESTED SKETCH

DETECTION OBJECTIVE

msaRAT Browser CDP Remote Debugging

Surface the source-observed behavior with the minimum defensible conditions.

STATUS

Production Candidate - Untested implementation sketch

No query in this dossier has been executed in the target environment.

KQL · DEMONSTRATIVE

DeviceProcessEvents
| where FileName in~ ("chrome.exe", "msedge.exe")
| where ProcessCommandLine contains "--headless"
| where ProcessCommandLine contains "--remote-debugging-port"
| project Timestamp, DeviceId, DeviceName, AccountName, FileName, FolderPath, ProcessCommandLine, InitiatingProcessFileName, InitiatingProcessCommandLine, SHA1, ReportId

REVIEW FIELDS · BASELINE LOCALLY · VALIDATE BEFORE PRODUCTION

WHY EACH CONDITION EXISTS

CONDITION	REASON
Browser image	Limits the search to the two browser families directly observed by Talos.
--headless	Represents the source-observed non-interactive browser launch.
--remote-debugging-port	Represents CDP exposure required by the observed browser-control mechanism.
No threshold	The source does not justify a count or time-window threshold.



TRIAGE AND INVESTIGATION

Evidence collection and disposition workflow.

SOC WORKFLOW

- 01

Confirm telemetry
Run the query over 30–90 days and group results manually by device role and parent process.
- 02

Reproduce safely
Execute a controlled headless CDP browser launch and confirm both flags are captured intact.
- 03

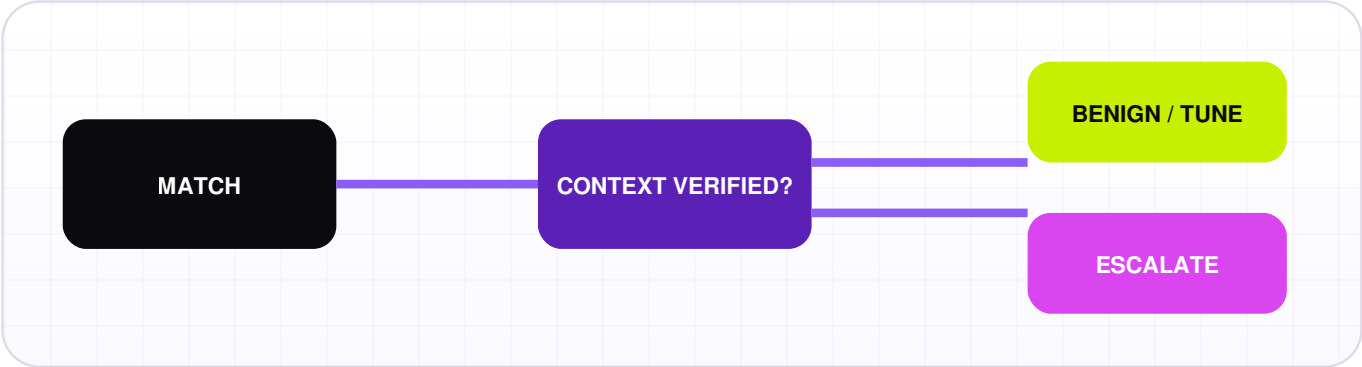
Investigate context
For each hit, review parent, profile directory, browser network events and software owner.
- 04

Apply decision gate
Reject promotion if authorized automation remains operationally indistinguishable.

INVESTIGATION PIVOTS

Host · user · process · file · network · identity

- Validate actor or parent identity.
- Collect full raw event and surrounding timeline.
- Confirm software owner and change context.
- Review adjacent endpoint, identity and network evidence.
- Preserve hashes and stable event identifiers.





FALSE POSITIVES AND VALIDATION

Baseline, test plan and operational promotion gate.

VALIDATION

FALSE-POSITIVE MATRIX

EXPECTED OVERLAP	LIKELIHOOD	TUNING ACTION
Playwright, Selenium or browser QA	Medium	Baseline automation hosts and parent processes.
Kiosk or synthetic monitoring	Medium	Confirm managed browser profile and service owner.
Developer troubleshooting	Low	Validate interactive user, ticket and short-lived test window.
Security research or sandboxing	Low	Allowlist only controlled lab assets, not generic parent names.

SUCCESS CRITERIA

Candidate can be separated from authorized activity

Legitimate sources are few, attributable and separable through stable parent, path or device-role controls.

REJECTION CRITERIA

Do not promote when evidence remains ambiguous

The environment produces high-volume browser automation without reliable ownership or lineage.

Promotion gate

Require representative baseline, preserved field semantics, documented exclusions, reproducible tests and analyst-readable output. Otherwise retain the current classification.



ATT&CK, CONCLUSION AND REFERENCES

Coverage summary, residual risk and document control.

CLOSURE

MITRE ATT&CK MAPPING

TECHNIQUE	NAME	EVIDENCE BASIS
T1219	Remote Access Software	Mapped only to the directly observed behavior.

ANALYST CONCLUSION

msaRAT Browser CDP Remote Debugging

The source-observed browser launch is a defensible production candidate because it combines two necessary CDP execution properties in one documented process event. Environmental baseline remains mandatory before alerting.

Residual risk

Telemetry gaps, altered attacker artifacts and authorized behavior can reduce precision. A query match is an investigative lead, not proof of compromise or attribution.

REFERENCES

- 1. Cisco Talos, “Chaos ransomware's msaRAT: Living off the browser to build a covert C2 channel,” 23 July 2026. <https://blog.talosintelligence.com/chaos-msarat-living-off-the-browser-to-build-covert-c2-channel/>
- 2. Official platform documentation. <https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table>
- 3. MITRE ATT&CK Enterprise technique T1219. <https://attack.mitre.org/techniques/T1219/>

DOCUMENT CONTROL

VERSION	DATE	STATUS	CHANGE SUMMARY
v1.0	24 July 2026	Production Candidate · Medium	Initial evidence-led dossier; untested implementation sketch.